ПРИЛОЖЕНИЕ К ПРОЕКТУ

Платёжный сервис

Кейс 1. Безопасный платёж за услугу

Команда «Экспонента»

Участник	Роль	Зона ответственности
Яковлева Ю.	аналитик	правила валидации, требования, словарь данных, контракт API, логика ошибок
Ревишнина Е.	разработчик	прототип (валидация, эмулятор шлюза), тесты T1-1…T1-5, скриншоты, коммиты в Git
Крылова А.	архитектор	схема системы и граф состояний, презентация, сборка приложения
Айкашева Л.	презентатор	методы подтверждения, текст выступления, журнал промптов, ответы на вопросы жюри

Содержание

A. Диаграммы: схема системы, сущности данных, схема состояний платежа

B. Таблицы: правила валидации, матрица «вход → код → HTTP», тесты, пользовательские сценарии, словарь данных

C. Журнал промптов

D. Матрица вклада

E. Артефакты: репозиторий, коммит, вывод прототипа, документация API, контрольные суммы, эмулятор шлюза

F. Чек-лист самопроверки

А. Диаграммы

А.1. Схема системы

Схема показывает систему целиком. Клиент (приложение клиники) обращается к платёжному сервису, сервис проверяет данные, сохраняет платёж и запрашивает результат у эмулятора шлюза; каждое действие попадает в журнал аудита.

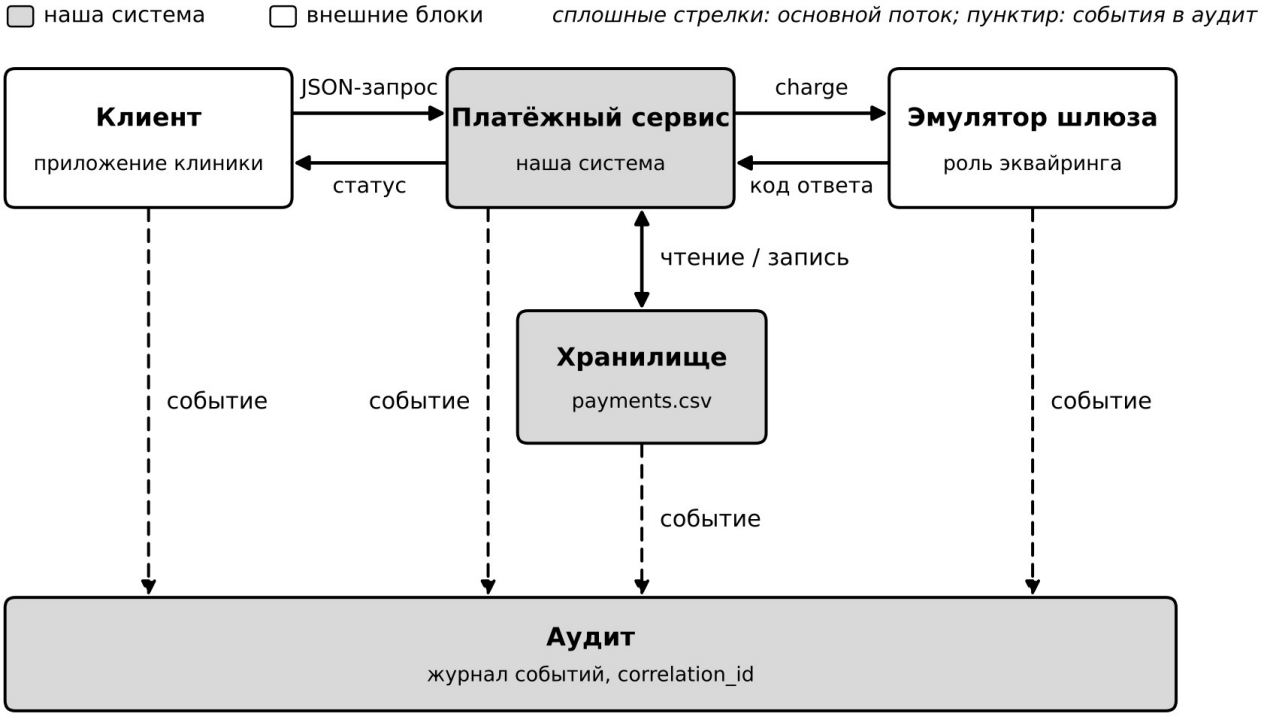


Рис. 1. Схема системы: пять блоков, потоки данных подписаны.

Блок	Что делает	Реализация в прототипе
Клиент	Приложение клиники: пациент выбирает услугу и нажимает «Оплатить», приложение формирует запрос	gui_app.py (веб-форма на Streamlit)
Платёжный сервис	Проверяет данные по правилам V-1…V-9, создаёт платёж, управляет статусами, защищает от двойного списания	05_app.py (validate, emulate_gateway, append_result); контракт API: 06_openapi.yaml
Эмулятор шлюза	Играет роль банка-эквайера: по order_id возвращает SUCCESS, DECLINED или TIMEOUT, всегда одинаково для одного order_id	emulate_gateway(); сценарии в 08_gateway_emulator.md
Хранилище	Хранит платежи и справочник получателей	payments.csv, recipients.csv; результаты прогона: payments_out.csv
Аудит	Фиксирует события с correlation_id, чтобы разбирать спорные случаи	журнал событий и gateway.log

Поток	Откуда → куда	Что передаётся
JSON-запрос	Клиент → Сервис	POST /api/v1/payments: order_id, recipient, purpose, amount, currency; заголовки Authorization (Bearer) и Idempotency-Key

Поток	Откуда → куда	Что передаётся
Статус	Сервис → Клиент	payment_id, status (CREATED), confirm_token со сроком жизни 600 с; далее GET /api/v1/payments/{id}
Подтверждение	Клиент → Сервис	POST /api/v1/payments/{id}/confirm: confirm_token и метод (card_token, sms_code, biometric_stub)
charge	Сервис → Эмулятор	POST /gateway/charge: order_id, amount, currency
Код ответа	Эмулятор → Сервис	status (SUCCESS, DECLINED или PENDING) и error_code
Чтение / запись	Сервис ↔ Хранилище	recipients.csv (проверка получателя), payments.csv (запись платежа)
Событие	Все блоки → Аудит	событие с correlation_id (например, payment.confirmed); gateway.log: timestamp, order_id, status, error_code, amount

Контракт API (06_openapi.yaml). Четыре метода платежа и проверка живости сервиса:

Метод и путь	Назначение	Коды ответа
POST /api/v1/payments	создание платежа и выдача токена подтверждения	201, 400, 404, 409, 422, 429
POST /api/v1/payments/{id}/confirm	подтверждение платежа токеном	200, 402, 410, 422, 504
GET /api/v1/payments/{id}	текущий статус платежа	200, 404
POST /api/v1/payments/{id}/cancel	отмена платежа до подтверждения	200, 409
GET /health	проверка живости сервиса	200

A.2. Сущности данных

Сущности данных проекта и связи между ними:

Сущность	Где хранится	Ключевые поля	Связи
Платёж	payments.csv	payment_id (ключ), order_id, recipient, purpose, amount, currency, status, error_code, idempotency_key, created_at, confirmed_at, correlation_id	ссылается на Получателя по полю recipient; один Idempotency-Key соответствует одному платежу
Получатель	recipients.csv	recipient_id (ключ), name, status (ACTIVE, INACTIVE, PENDING, BLOCKED)	у одного получателя много платежей
Токен подтверждения	кэш или БД сервиса	confirm_token, payment_id, срок жизни 600 с, одноразовый	один токен на один платёж в статусе CREATED
Событие аудита	журнал аудита	название события, correlation_id, время	много событий на один платёж (общий correlation_id)
Запись шлюза	gateway.log	timestamp, order_id, status, error_code, amount	по одной записи на попытку списания, связь по order_id

Набор данных. payments.csv содержит 100 платежей: SUCCESS 70, DECLINED 10, ERROR 8, PENDING 7, CANCELED 5. recipients.csv содержит 41 получателя: ACTIVE 32, INACTIVE 5,

PENDING 2, BLOCKED 2. Статус ERROR в наборе данных означает запрос, отклонённый валидацией (коды VALIDATION_ERROR, RECIPIENT_NOT_FOUND, UNSUPPORTED_CURRENCY, DUPLICATE_ORDER, AMOUNT_OUT_OF_RANGE).

A.3. Схема состояний платежа

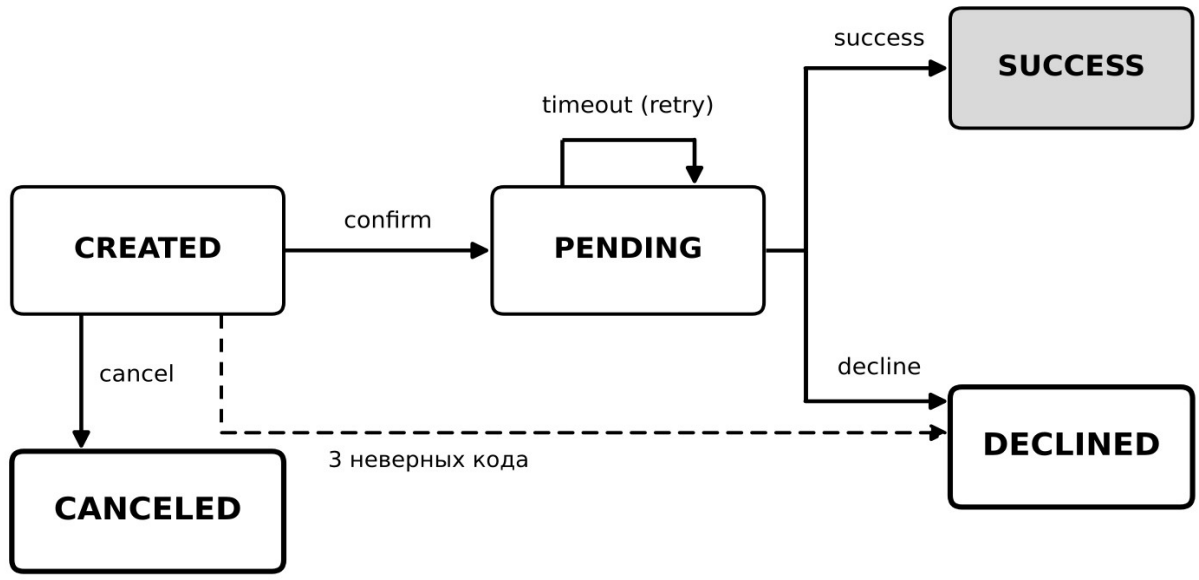


Рис. 2. Состояния платежа и переходы. Таймаут шлюза оставляет платёж в PENDING.

Переход	Что переводит платёж	Условие
старт → CREATED	клиент создал платёж	запрос прошёл проверки V-1…V-9, выдан confirm_token на 600 с
CREATED → PENDING	клиент подтвердил (confirm)	верный confirm_token и метод подтверждения; сервис отправил запрос в шлюз
PENDING → SUCCESS	эмулятор вернул SUCCESS	hash(order_id) mod 10 = 0…6
PENDING → DECLINED	эмулятор вернул отказ	mod 10 = 7 (INSUFFICIENT_FUNDS) или 8 (CARD_DECLINED)
PENDING → PENDING	эмулятор вернул TIMEOUT	mod 10 = 9; клиент безопасно повторяет запрос с тем же Idempotency-Key
CREATED → CANCELED	клиент отменил (cancel)	до подтверждения; также токен не использован за 600 с
CREATED → DECLINED	сервис	три неверных ввода кода подтверждения

Почему таймаут не ведёт в ошибку. Если шлюз не ответил, мы не знаем, прошла ли оплата. Окончательный статус в этом случае привёл бы к повторной оплате и двойному списанию. Поэтому платёж остаётся в PENDING, а повтор с тем же Idempotency-Key возвращает прежний результат и не создаёт нового списания. Финальные статусы (SUCCESS, DECLINED, CANCELED) не имеют выходящих переходов.

B. Таблицы

B.1. Правила валидации V-1…V-9

ID	Условие	Действие	Код ошибки	Обоснование
V-1	обязательное поле пустое	отклонить	VALIDATION_ERROR	обязательные поля нужны для минимальной идентификации платежа в учётных системах клиники
V-2	order_id не по regex ^[A-Za-z0-9_\-]{1,64}$	отклонить	INVALID_FORMAT	строгий формат защищает базу данных от SQL-инъекций и сбойных символов
V-3	amount ≤ 0 или > 1 000 000	отклонить	AMOUNT_OUT_OF_RANGE	лимиты защищают клинику от ошибок ввода и крупных фрод-транзакций
V-4	currency не в [RUB]	отклонить	UNSUPPORTED_CURRENCY	расчёты внутри медицинских учреждений ведутся в рублях по требованиям законодательства РФ
V-5	recipient не найден в recipients.csv или его статус не ACTIVE	отклонить	RECIPIENT_NOT_FOUND	нельзя переводить деньги неактивному или несуществующему получателю: это нарушает финансовый контроль
V-6	purpose длиннее 200 символов или содержит номер карты (PAN, \d{13,19})	отклонить	INVALID_PURPOSE	запрет PAN защищает платёжные данные клиентов от попадания в открытые логи
V-7	в amount больше 2 знаков после точки	отклонить	INVALID_AMOUNT_PRECISION	ограничение точности предотвращает ошибки округления и манипуляции с микросуммами
V-8	пара order_id + recipient уже есть в базе	вернуть существующий платёж (HTTP 409)	DUPLICATE_ORDER	блокировка дубликатов защищает пациента от двойного списания при случайном повторном клике
V-9	повтор Idempotency-Key	вернуть сохранённый ответ (HTTP 200)	DUPLICATE_REQUEST	кэш ответов делает сетевые повторы безопасными: прошлый результат возвращается без нового платежа

B.2. Матрица «вход → код ошибки → HTTP»

Ситуация	Код ошибки	HTTP	Retryable
Обязательное поле пустое (V-1)	VALIDATION_ERROR	422	нет, нужно исправить данные
order_id не по формату (V-2)	INVALID_FORMAT	422	нет
Сумма ≤ 0 или > 1 000 000 (V-3)	AMOUNT_OUT_OF_RANGE	422	нет
Валюта не RUB, например USD (V-4)	UNSUPPORTED_CURRENCY	422	нет
Получатель не найден или не ACTIVE (V-5)	RECIPIENT_NOT_FOUND	404	нет
purpose длиннее 200 символов или с номером карты (V-6)	INVALID_PURPOSE	422	нет

Ситуация	Код ошибки	HTTP	Retryable
Больше 2 знаков после точки (V-7)	INVALID_AMOUNT_PRECISION	422	нет
Дубликат order_id + recipient (V-8)	DUPLICATE_ORDER	409	нет, возвращается существующий платёж
Повтор Idempotency-Key (V-9)	DUPLICATE_REQUEST	200	да, безопасно: idempotent_replay = true
Недостаточно средств (шлюз, mod 10 = 7)	INSUFFICIENT_FUNDS	402	нет, статус DECLINED
Карта отклонена (шлюз, mod 10 = 8)	CARD_DECLINED	402	нет, статус DECLINED
Таймаут шлюза (mod 10 = 9)	TIMEOUT	504	да, статус PENDING
Токен подтверждения использован или истёк	—	410	нет
Платёж не найден	—	404	нет
Отмена после подтверждения	—	409	нет
Слишком много запросов	—	429	да, позже

Коды HTTP соответствуют контракту 06_openapi.yaml. Для ситуаций без кода ошибки (410, 404, 409, 429) каталог ошибок отдельных кодов не вводит.

B.3. Тесты T1-1…T1-5

ID	Вход	Ожидание	Факт	Пройден
T1-1	**Успешная оплата** order_id = ord_1001, amount = 2500.00 RUB, recipient = clinic_medservice, ключ idem_0001	статус SUCCESS запись в payments_out.csv error_code отсутствует	Скрипт вернул SUCCESS, запись создана	**да**
T1-2	**Отказ шлюза** order_id = ord_2001, amount = 3000.00 RUB, ключ idem_0002 (по хэшу эмулятор отклоняет карту)	статус DECLINED error_code = INSUFFICIENT_FUNDS или CARD_DECLINED	Скрипт вернул DECLINED, error_code = CARD_DECLINED	**да**
T1-3	**Неверные данные** order_id = ord_1009, currency = USD (нарушено правило V-4)	платёж отклонён, HTTP 422 error_code = UNSUPPORTED_CURRENCY	Скрипт вернул VALIDATION_ERROR с кодом UNSUPPORTED_CURRENCY; запись в CSV не добавлена	**да**
T1-4	**Повтор запроса (идемпотентность)** два запроса с одинаковым Idempotency-Key idem_0001 и order_id = ord_1001	второй запрос не создаёт дубликат тот же payment_id и статус, HTTP 200 в payments_out.csv одна запись	Второй запрос вернул тот же ответ с флагом idempotent_replay: true; дубликат в CSV не создан	**да**
T1-5	**Таймаут эмулятора** order_id = ord_2016, amount = 2200.00 RUB, ключ idem_0005 (по хэшу эмулятор возвращает TIMEOUT)	клиенту возвращается статус PENDING в логах зафиксирован TIMEOUT повторный запрос с тем же ключом безопасен	Скрипт вернул PENDING и error_code = TIMEOUT; в CSV добавлена запись	**да**

Входные данные тестов лежат в файлах t1_1_success.json, t1_2_declined.json, t1_3_invalid.json, t1_4_replay.json и t1_5_timeout.json. Все пять тестов пройдены.

B.4. Пользовательские сценарии

Сценарий	Шаги	Тест
1. Успешная оплата	1. Пациент выбирает услугу в приложении клиники и нажимает «Оплатить». 2. Приложение отправляет запрос на создание платежа, данные проходят валидацию, пациенту выводится форма ввода СМС-кода. 3. Пациент вводит корректный СМС-код, сервис обращается к шлюзу (по хэшу order_id выпадает SUCCESS), списывает деньги и показывает экран успешной оплаты.	T1-1
2. Отказ банка (карта отклонена)	1. Пациент нажимает «Оплатить», сервис успешно создаёт платёж и генерирует форму подтверждения. 2. Пациент подтверждает платёж СМС-кодом, но эмулятор шлюза (по хэшу order_id выпадает сценарий 8) отклоняет операцию. 3. Пациент видит на экране сообщение: «Платёж отклонён. Банк отклонил операцию по вашей карте».	T1-2
3. Невалидные данные	1. Пациент нажимает «Оплатить», но в запросе передана отрицательная сумма или валюта USD. 2. Сервис не создаёт платёж, а возвращает ошибку 422 с кодом AMOUNT_OUT_OF_RANGE или UNSUPPORTED_CURRENCY. 3. Пациент видит сообщение «Проверьте данные и попробуйте снова» и исправляет сумму.	T1-3
4. Повторная отправка	1. Пациент нажимает «Оплатить», запрос уходит с Idempotency-Key = idem_0001, платёж создан. 2. Связь обрывается, пациент нажимает «Оплатить» ещё раз, уходит тот же Idempotency-Key. 3. Сервис возвращает тот же payment_id без второго списания, пациент видит тот же результат.	T1-4

B.5. Словарь данных

Поле	Тип	Обяз.	Ограничение	Пример	Код ошибки	Комментарий
payment_id	string	да (сервер)	UUID v4 или pay_NNNN	pay_0001	—	генерирует сервис
order_id	string	да	1–64, ^[A-Za-z0-9_\-]+$	ord_1001	INVALID_FORMAT	идентификатор заказа клиники
recipient	string	да	1–64, ID из recipients.csv, статус ACTIVE	clinic_medservice	RECIPIENT_NOT_FOUND	получатель средств
purpose	string	да	1–200, без PAN	Приём терапевта	INVALID_PURPOSE	назначение платежа
amount	number	да	> 0, ≤ 1 000 000, 2 знака	2500.00	AMOUNT_OUT_OF_RANGE / INVALID_AMOUNT_PRECISION	сумма в рублях
currency	string	да	enum [RUB]	RUB	UNSUPPORTED_CURRENCY	валюта (ISO 4217)
status	string	да (сервер)	CREATED, PENDING, SUCCESS, DECLINED, ERROR, CANCELED	SUCCESS	—	состояние платежа
error_code	string	нет	из каталога ошибок или пусто	null	—	причина отказа шлюза или валидации
idempotency_key	string	да	8–64, уникален 24 часа	idem_0001	DUPLICATE_REQUEST	защита от двойного списания
created_at	string	да (сервер)	ISO 8601	2025-11-01T08:00:00Z	—	время создания
confirmed_at	string	нет	ISO 8601	null	—	время подтверждения
correlation_id	string	да (сервер)	corr_NNNN	corr_0001	—	сквозной ID для трассировки

C. Журнал промптов

В таблице приведены запросы к ИИ-ассистенту, использованные при работе над проектом. Каждый результат проверялся и дорабатывался командой вручную.

Дата	Цель	Промпт (сжато)	Результат	Проверка	Использовано
01.11	Понять термин «идемпотентность» перед тем, как писать V-9	«Объясни простыми словами, что такое идемпотентность в платежах, зачем нужен Idempotency-Key»	Понятное объяснение и пример с повторным нажатием «Оплатить»	Сверили с 02_правила.md, переписали своими словами	Переработано
01.11	HTTP-коды для каждого вида ошибки	«Дай таблицу: ситуация → код ошибки → HTTP-статус → retryable. Только по нашему каталогу: VALIDATION_ERROR, INVALID_FORMAT, AMOUNT_OUT_OF_RANGE, UNSUPPORTED_CURRENCY, RECIPIENT_NOT_FOUND, INVALID_PURPOSE, INVALID_AMOUNT_PRECISION, DUPLICATE_ORDER, DUPLICATE_REQUEST»	Таблица-черновик	Проверили каждую строку по payments.csv, поправили 402/422 вручную	Переработано
02.11	Набросать каркас validate() на Python	«Функция validate на Python с проверкой суммы, валюты и regex для order_id. Верни список ошибок вида (field, code)»	Каркас функции	Проверили каждую строку, дописали V-5…V-9 и чтение recipients.csv сами	Да
02.11	Уточнить формулу эмулятора шлюза	«Как детерминированно выбрать один из 4 результатов по строке order_id? Хочу hash mod N»	md5 → int → % 10, разбивка 0-6/7/8/9	Сверили с 08_gateway_emulator.md, проверили, что одинаковый order_id даёт одинаковый результат	Да
03.11	Проверить схему состояний платежа	«Перечисли переходы статусов: CREATED, PENDING, SUCCESS, DECLINED, ERROR, CANCELED — что в что переходит и по какому событию»	Список переходов	Сверили со 09_приложение.docx (схема состояний), убрали лишнее	Переработано
03.11	Проверить OpenAPI на ошибки	«Открывается ли этот yaml в Swagger Editor? Что может сломать валидацию?» — приложили 06_openapi.yaml	Список замечаний	Открыли в editor.swagger.io, сами поправили схемы и методы	Да
04.11	Подсказать формулировки для рисков	«Какие риски у платёжного сервиса без реального эквайринга? Двойное списание, утечка PAN, таймаут — дай по 1 мере на риск»	Черновик таблицы рисков	Проверили, что митигация реально реализована в правилах V-6, V-8, V-9	Переработано

D. Матрица вклада

Участник	Файлы / задачи	Часы	Подпись
Яковлева Ю.	06_openapi.yaml, 02_правила.md, 04_требования.md, 03_data_dictionary.md, 08_gateway_emulator.md. Проработка логики ошибок и матрицы статусов.	12	
Ревишнина Е.	Написание и отладка кода 05_app.py (функции валидации и эмулятора шлюза), проведение тестов T1-1…T1-5, снятие скриншотов консоли, коммит в Git	12	
Крылова А.	Отрисовка схемы системы и графа состояний платежа (draw.io), оформление презентации, сборка pdf-приложения	11	
Айкашева Л.	07_методы.md. Написание текста выступления, заполнение журнала промптов ИИ, подготовка ответов на вопросы жюри, репетиция защиты	10	

E. Артефакты

E.1. Репозиторий

Репозиторий команды «Экспонента»: https://github.com/veta-vish/team3_case1.git

E.2. Последний коммит

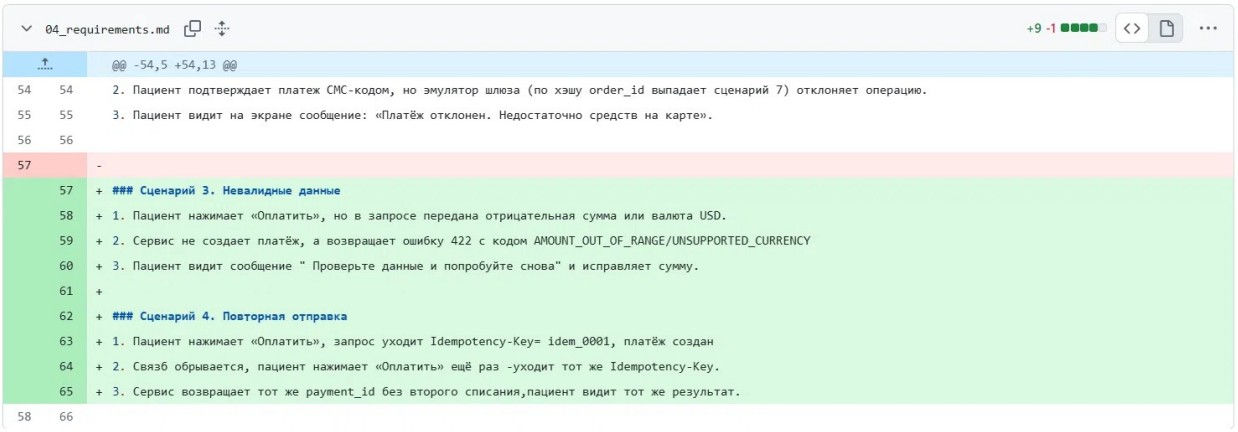


Рис. 3. Последний коммит: в 04_requirements.md добавлены пользовательские сценарии 3 и 4.

E.3. Вывод прототипа

Запуск прототипа на входных файлах тестов (python 05_app.py <файл>):

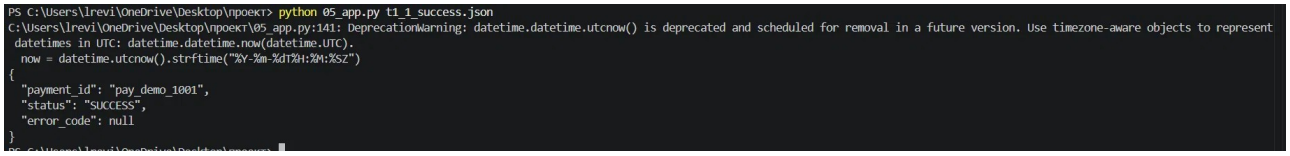


Рис. 4. T1-1, успешная оплата: статус SUCCESS.

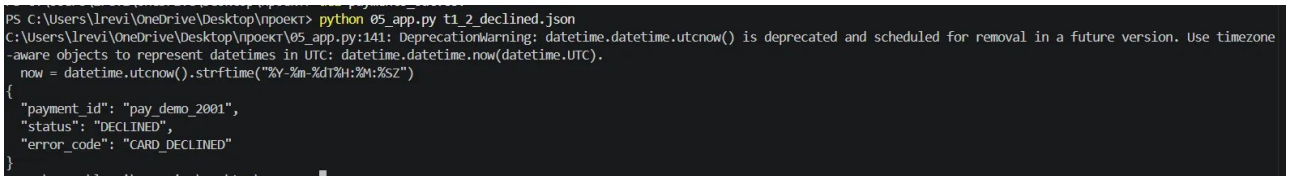


Рис. 5. T1-2, отказ шлюза: статус DECLINED, error_code = CARD_DECLINED.

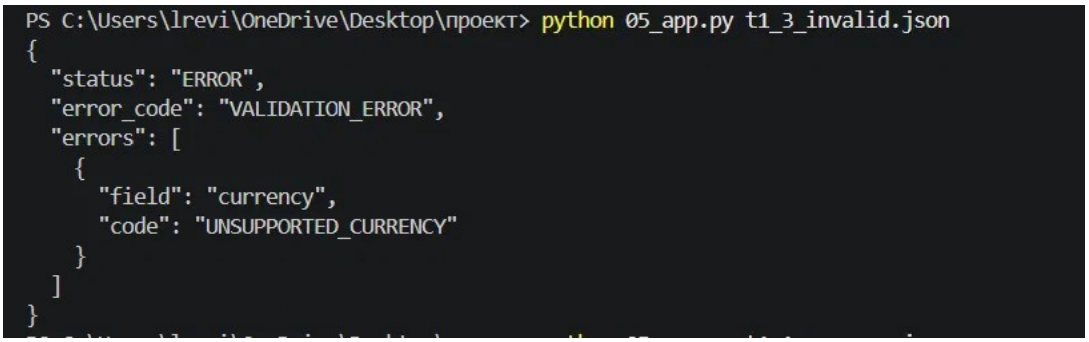


Рис. 6. T1-3, неверная валюта: VALIDATION_ERROR, код UNSUPPORTED_CURRENCY.

```
PS C:\Users\lrevi\OneDrive\Desktop\проект> python 05_app.py t1_4_replay.json
{
  "payment_id": "pay_demo_1001",
  "status": "SUCCESS",
  "error_code": null,
  "idempotent_replay": true
}
PS C:\Users\lrevi\OneDrive\Desktop\проект>
```

Рис. 7. T1-4, повторный запрос: тот же платёж, idempotent_replay = true.

```
PS C:\Users\lrevi\OneDrive\Desktop\проект> python 05_app.py t1_5_timeout.json
C:\Users\lrevi\OneDrive\Desktop\проект\05_app.py:141: DeprecationWarning: datetime.datetime.utcnow() is deprecated and scheduled for removal
 in a future version. Use timezone-aware objects to represent datetimes in UTC: datetime.datetime.now(datetime.UTC).
  now = datetime.utcnow().strftime("%Y-%m-%dT%H:%M:%SZ")
{
  "payment_id": "pay_demo_2016",
  "status": "PENDING",
  "error_code": "TIMEOUT"
}
```

Рис. 8. T1-5, таймаут шлюза: статус PENDING, error_code = TIMEOUT.

E.4. Документация API (Swagger UI)

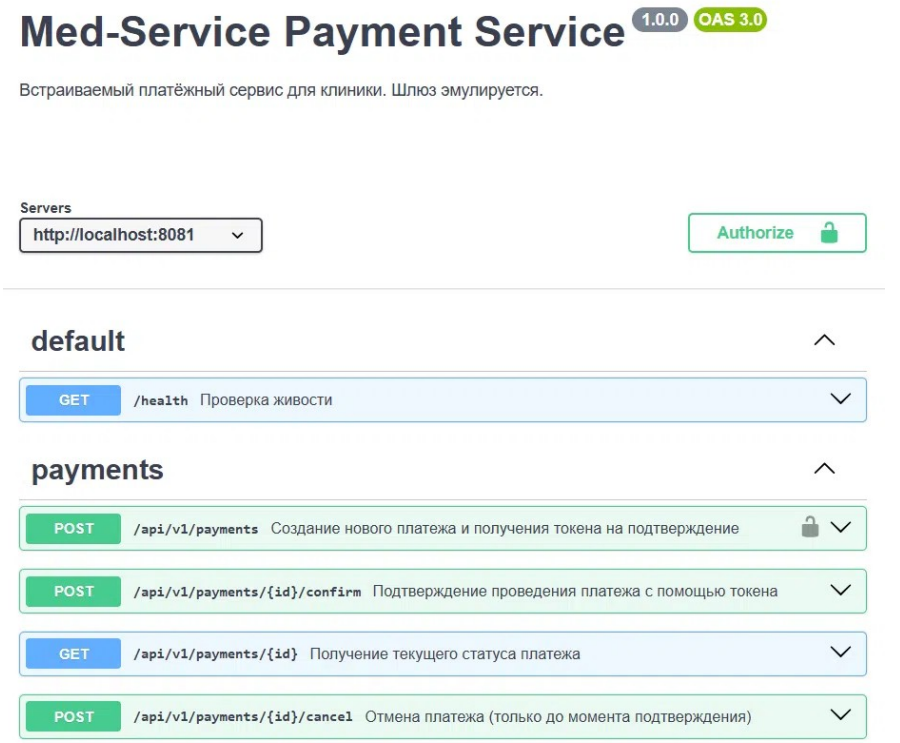


Рис. 9. Swagger UI: четыре метода платежа и проверка живости сервиса (OpenAPI 3.0).

E.5. Контрольные суммы данных

Контрольные суммы подтверждают, что файлы данных не менялись:

```
$ md5sum 01_данные/payments.csv
39a94a80f541e44c72362304ccc3904b  01_данные/payments.csv
$ md5sum 01_данные/recipients.csv
3cfdb2057a89b05241f6555b1c10d3f8  01_данные/recipients.csv
```

E.6. Воспроизводимость эмулятора шлюза

Эмулятор выбирает результат по формуле md5(order_id) mod 10, поэтому один и тот же order_id всегда даёт один и тот же результат (08_gateway_emulator.md). Сценарии:

№	Условие	Результат	error_code	Задержка
1	mod 10 = 0…6	SUCCESS	—	0–2 с
2	mod 10 = 7	DECLINED	INSUFFICIENT_FUNDS	1–2 с
3	mod 10 = 8	DECLINED	CARD_DECLINED	1–2 с
4	mod 10 = 9	PENDING	TIMEOUT	5 с (таймаут)

Расчёт для order_id из тестов:

order_id	mod 10	Результат шлюза	Тест
ord_1001	1	SUCCESS	T1-1 и T1-4 (повтор даёт тот же результат)
ord_2001	8	DECLINED, CARD_DECLINED	T1-2
ord_2016	9	PENDING, TIMEOUT	T1-5
ord_1009	4	не доходит до шлюза	T1-3: платёж отклонён валидацией (USD)

F. Чек-лист самопроверки

- [x] Схема системы: 4–6 блоков, потоки подписаны
- [x] Схема состояний платежа с переходами
- [x] ER-модель (если бонус) или перечисление сущностей
- [x] Правила V-1…V-9 с обоснованием
- [x] Матрица «вход → код → HTTP → retryable»
- [x] Тесты T1-1…T1-5 с фактом
- [x] Журнал промптов (или «ИИ не использовался»)
- [x] Матрица вклада: 4 человека, задачи разные
- [x] Git-ветка и коммит
- [x] Скрин прототипа (если есть)
- [x] Файл экспортирован в PDF до начала защиты